

CYBER SECURITY

HTTPS://SUVIKSAN.IN



CYBER WINTER

- WEEK 1 - INTRODUCTION TO CYBERSECURITY AND ETHICAL HACKING WITH SYLLABUS DISTRIBUTION
- WEEK 2 - NETWORKING FUNDAMENTALS FOR ETHICAL HACKING
- WEEK 3 - INTRODUCTION TO FOOTPRINTING AND RECONNAISSANCE
- WEEK 4 - SCANNING AND ENUMERATION TECHNIQUES
- WEEK 5 - SYSTEM AND NETWORK EXPLOITATION BASICS WITH WIRELESS ATTACKS
- WEEK 6 - WEB APPLICATION SECURITY FUNDAMENTALS , REMEDIATIONS AND REPORTING

OVERVIEW OF THIS WEEK



1. Ethical and unethical hacking phases and steps.
2. What and Importance of footprinting.
3. Types of footprinting (active vs. passive).
4. DNS fundamentals.
5. Reconnaissance tools like nslookup, Nmap, Shodan, etc.
6. Legal and ethical considerations.
7. Practical exercises.

PHASES OF HACKING

Ethical hacking is a systematic approach consisting of several key phases. Each phase builds upon the previous one to simulate a real-world attack or identify vulnerabilities.

1. Reconnaissance or Information Gathering or Footprinting

The initial stage where the hacker gathers as much information as possible about the target system, network, or organization with the objective to identify entry points and gather intelligence without interacting directly with the target in some cases.

2. Scanning and Enumeration

The process of actively probing the target system to identify open ports, active devices, services, and vulnerabilities with the objective of gaining access to the system.

3. Gaining Access

Exploiting vulnerabilities discovered during the scanning phase to gain unauthorized access or simply to take control of the target system or extract valuable information.



PHASES OF HACKING

4. Maintaining Access

After gaining access, the hacker ensures persistent access to the system for future use to avoid detection and maintain control over the target.

For Maintaining access, hackers normally uses Backdoors, rootkits.

5. Clearing Tracks and Logs

A unethical hacker erases all evidences of the hacking activities to prevent detection or forensic investigation but an ethical hacker do it for preventing the affected asset and attack to be seen by any outsider or unethical hacker.

6. Reporting

Now in the end of all hacking phase, ethical hacker creates a detail report for the company or the client. So that those errors and vulnerabilities be patched.

There are lots of things mentioned in detailed report: All Vulnerabilities Summary, One-by-One Vulnerability name, description, CVSS Scoring, Attack Scenario, Remediation, How the Vulnerability is found out, place the vulnerability occurred and POCs



RECONNAISSANCE / FOOTPRINTING

What is Footprinting?

Footprinting is the process of gathering detailed information about a target organization, system, or network to understand its structure, potential vulnerabilities, and the environment in which it operates. It forms the foundation of any hacking attempt, whether ethical or unethical.



Why is Footprinting Important?

1. **Laying the Groundwork for Attacks:** Provides a clear picture of the target's external-facing resources, enabling an attacker to plan their strategy effectively which helps in minimizing trial-and-error during subsequent phases like scanning or exploitation.
2. **Risk Assessment for Defensive Strategies:** Footprinting identifies potential weaknesses or misconfigurations that attackers may exploit.
3. **Uncovering Hidden Weak Points:** Detects IT assets, unsecured endpoints, and outdated systems. Reveals sensitive data inadvertently exposed online, such as via GitHub repositories or misconfigured cloud storage.
4. **Enhancing Ethical Hacking Effectiveness:** Penetration testers use footprinting to simulate real-world attacks and evaluate security postures which helps in providing actionable recommendations to improve defenses.

TYPES OF INFORMATION COLLECTED DURING FOOTPRINTING

01 **Network Details:**
- Public IP addresses, subnet masks, and accessible network ranges.
- Internet service provider (ISP) and hosting provider details.

02 **Domain Information:**
- WHOIS details (registrar, admin contact, expiration date, etc.).
- Subdomains, DNS records, and zone transfers.

03 **System Information:**
- OS type, software versions, open ports, and services running.

04 **Organizational Data:**
- Employee roles, email addresses, phone numbers, and locations (gathered via social engineering or OSINT).

05 **Sensitive Data:**
- Password dumps, credentials, or exposed configurations found on public repositories, forums, or breached databases.



Winter Training

COMMON FOOTPRINTING TECHNIQUES

NIELIT

01 **Search Engines and Advanced Queries (Google Dorking):**
- Using search engine operators to uncover hidden information (e.g., site:example.com, filetype:pdf password).

02 **WHOIS and DNS Lookup:**
- To find domain ownership, server details, and DNS configurations. Tools include: WHOIS, nslookup, dig, DNSDumpster, DNSRecon.

03 **Social Engineering:**
- Posing as trusted personnel to extract sensitive information with the help of Fake phishing emails and much more attacks.

04 **Social Media Analysis:**
- Collecting information about employees, projects, or organizational culture via LinkedIn, Facebook, or Twitter.



05 **Scanning Public Code Repositories:**
- Checking GitHub, GitLab, or Bitbucket for exposed code, credentials, or sensitive files.

06 **Online Directories and Data Dumps:**
- Using platforms like Shodan for device information or searching breach data on Have I Been Pwned.

TYPES OF FOOTPRINTING // ACTIVE FP



In Active Footprinting, there is direct interaction with the target system or network to gather information.

01

Characteristics:

- Detectable by the target (due to logs or alerts).
- Requires tools or techniques that interact with the target system.

02

Techniques:

- **Ping Sweeps:** Identify active hosts on the network.
- **Port Scanning:** Determine which ports are open or closed using tools like Nmap.
- **Traceroute:** Map the path to the target system.
- **DNS Zone Transfers:** Gather DNS record information from a DNS server.

03

Tools:

- Nmap, traceroute, dig, nslookup, and Shodan.

04

Practical Example:

- A penetration tester runs an Nmap scan to identify open ports on a company's firewall, which might alert the company's intrusion detection system (IDS).

TYPES OF FOOTPRINTING / PASIVE FP



In Passive Footprinting, gathering information about the target is done without direct interaction with the target by typically using publicly available resources.

01 **Characteristics:**

- Difficult to detect.
- Relies on OSINT (Open-Source Intelligence).

02 **Techniques:**

- **Search Engines (Google Dorking):** Using advanced search operators to locate exposed data.
- **WHOIS Lookup:** Gathering domain registration details.
- **Public Records Analysis:** Examining organizational filings, news articles.
- **Social Media Scraping:** Collecting personal or professional information shared on platforms like LinkedIn or Twitter.

03 **Tools:**

- Google, WHOIS, Maltego, and Recon-ng.

04 **Practical Example:**

- In 2020, a major data breach occurred because attackers found admin credentials exposed in a public GitHub repository. This was discovered during passive footprinting.

DEFENSIVE COUNTERMEASURES AGAINST FOOTPRINTING



01 **Limit Exposed Information:**
- Use privacy protection for WHOIS records.
- Restrict subdomain access and hide internal servers from public DNS.

02 **Monitor Publicly Available Data:**
- Perform regular OSINT checks on your own organization.
- Use tools like Google Alerts or automated OSINT platforms.

03 **Implement Network and Endpoint Security:**
- Use firewalls to block unauthorized scanning and access.
- Ensure up-to-date software and patch management.

04 **Educate Employees:**
- Train staff to recognize social engineering attempts and avoid oversharing on social media.

OVERVIEW OF TOOLS USED FOR FOOTPRINTING

- **Nslookup:** Nslookup (short for "name server lookup") is a command-line tool used to query DNS servers for domain name or IP address information.
- **Nmap (Network Mapper):** Nmap is a powerful, open-source tool used to scan networks and gather detailed information about hosts on a network.
- **IP Logger:** IP Logger is an online tool that tracks and logs IP addresses by creating a unique tracking link.
- **Grabify IP Logger:** Grabify is another IP logging service that allows users to track the IP addresses of users who click on a generated link.
- **Wireshark:** A network protocol analyzer used for real-time traffic monitoring.
- **Maltego:** A tool for deep data mining and information gathering.
- **Recon-ng:** A reconnaissance framework specifically for web-based reconnaissance.
- **theHarvester:** A tool for collecting emails, subdomains, IPs, and URLs associated with a domain.
- **shodan:** A search engine for discovering internet-connected devices.
- **FOCA (Fingerprinting Organizations with Collected Archives):** A document metadata analysis tool.
- **SpiderFoot:** An OSINT (Open-Source Intelligence) tool for automated reconnaissance.
- **Social Engineering Tools (SET):** Tools that support social engineering reconnaissance.

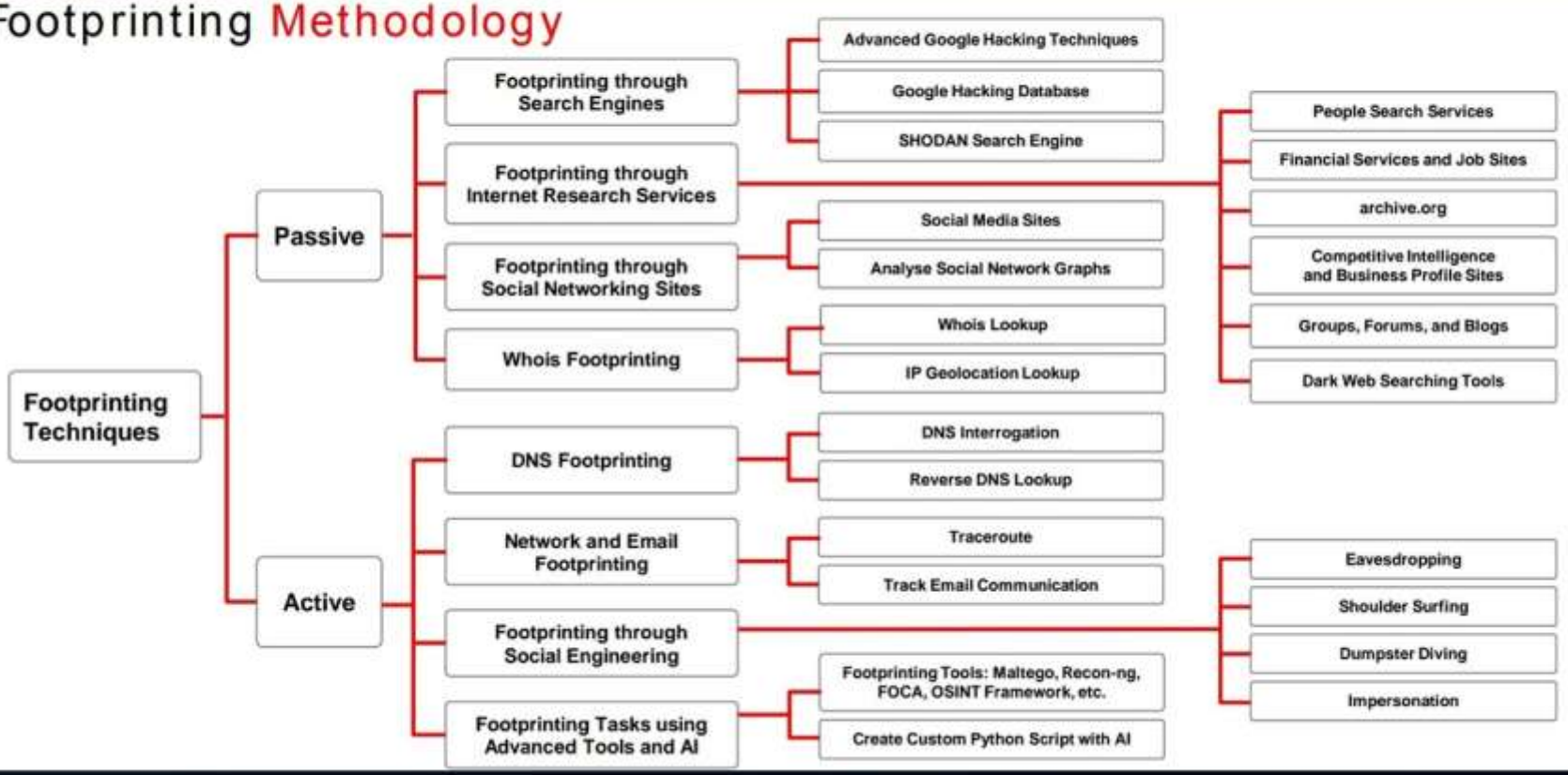
More tools are there which is used in footprinting like: Wayback Machine, GHDB, MW Metadata, pentest-tools.com, Startpage.com, onionland.io, buzzsumo.com, DNSDumpsterm, Sublist3r.

OVERVIEW OF TOOLS USED FOR FOOTPRINTING

Tools	Windows	Linux	Type	Functionality
Nmap	✔	✔	CLI	Network and port scanning, OS detection, service versioning
Zenmap	✔	✔	GUI	GUI version of Nmap for easier usability
Wireshark	✔	✔	GUI	Packet capture and network protocol analysis
Netcat	✔	✔	CLI	Port scanning, banner grabbing, reverse shell creation
Traceroute	✔ (tracert)	✔	CLI	Tracks the route of packets to a destination
Whois	✔	✔	CLI	Retrieves domain registration details
Nslookup/Dig	✔	✔	CLI	DNS querying and information retrieval
TCPdump	✔ (via Cygwin/WSL)	✔	CLI	Packet capture and network traffic analysis
HTTrack	✔	✔	Both (CLI/GUI)	Website mirroring and offline browsing
cURL	✔	✔	CLI	Fetches website headers, content, or files using protocols
Sherlock	✔	✔	CLI	Finds usernames across multiple social media platforms
Maltego CE	✔	✔	GUI	OSINT analysis, relationship mapping, entity extraction
Fierce	✔	✔	CLI	DNS enumeration and subdomain discovery
Nikto	✔	✔	CLI	Web server scanning for vulnerabilities and misconfigurations
Metasploit (msfconsole)	✔	✔	CLI	Exploiting vulnerabilities, gathering service information
theHarvester	✔	✔	CLI	Gathers emails, subdomains, hosts, and employee information
Email2phonenumber	✔	✔	CLI	Converts email addresses into associated phone numbers
Shodan CLI	✔	✔	CLI	Searches for internet-connected devices and vulnerabilities
Have I Been Pwned API (HIBP)	✔	✔	CLI	Checks leaked credential databases for exposed accounts
CeWL	✔	✔	CLI	Generates wordlists from websites for password cracking
AWSRecon	✔	✔	CLI	Extracts publicly accessible AWS account details

FOOTPRINTING METHODOLOGY

Footprinting Methodology



DNS / DOMAIN NAME SYSTEM



The Domain Name System (DNS) works like the internet's phone book. It helps translate website names (like google.com) into IP addresses, which are unique numbers that computers use to find each other on the internet.

How Does DNS works?

01 **User Request:** A user enters a domain name (e.g., www.example.com) in their browser.

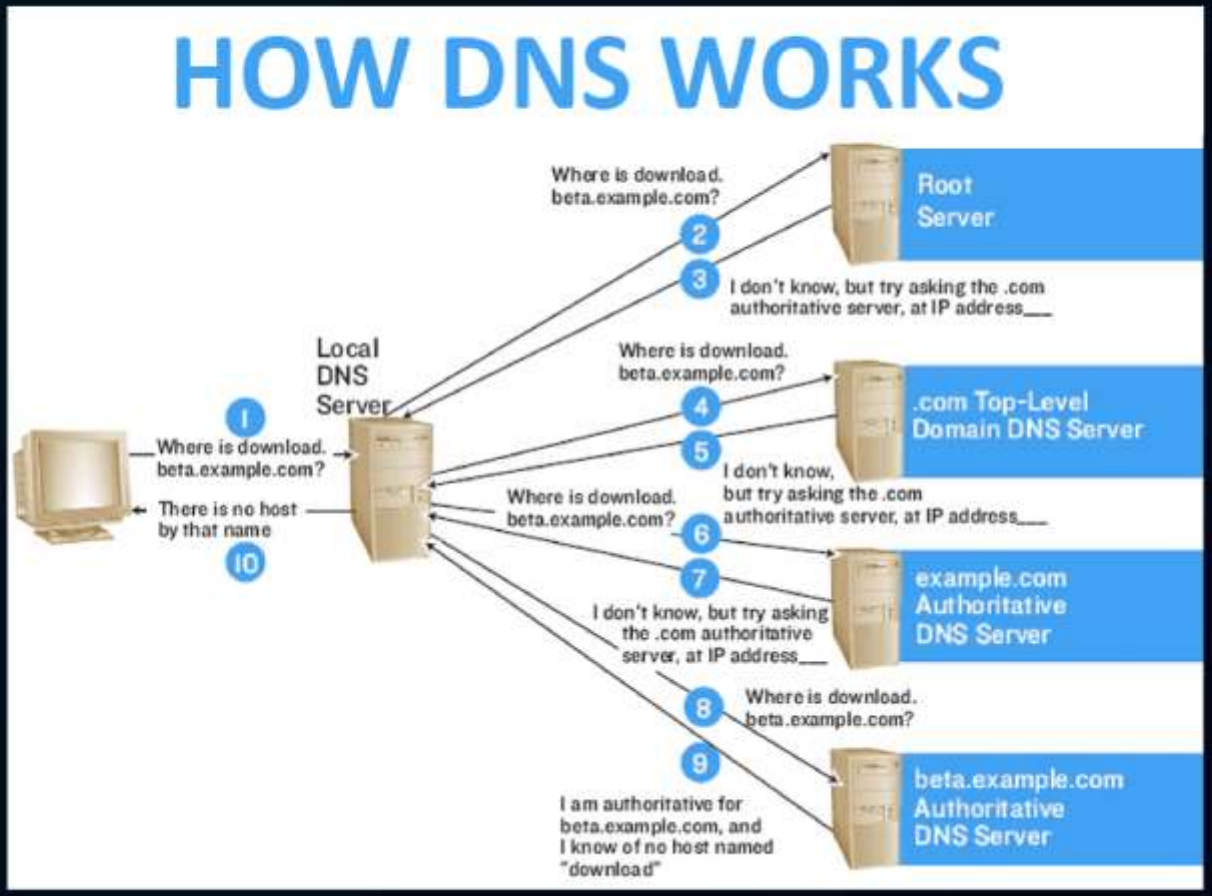
02 **DNS Query Process:** The browser sends a query to a DNS resolver to find the corresponding IP address.

03 **Resolver's Role:** The resolver checks its cache; if the record isn't found, it queries the DNS hierarchy:

- **Root DNS Server**: Points to the appropriate Top-Level Domain (TLD) server.
- **TLD DNS Server**: Points to the authoritative DNS server for the domain.
- **Authoritative DNS Server**: Returns the IP address of the domain.

04 **Response to the Browser:** The IP address is returned to the browser, which connects to the web server hosting the website.

WORKING OF DOMAIN NAME SYSTEM



COMPONENTS AND TYPES OF DNS



Components of DNS

01 **Root Servers:** There are 13 logical root servers globally, managed by multiple organizations which act as the starting point for all DNS lookups.

02 **TLD (Top-Level Domain) Servers:** Handle requests for specific domain extensions (e.g., .com, .org, .net).

03 **Authoritative DNS Servers:** Store DNS records for specific domains and provide the final answer to queries.

04 **Recursive Resolver:** Acts as an intermediary between the client and the DNS hierarchy to resolve the query.

Types of DNS records

- **A Record**: Maps a domain to an IPv4 address.
- **AAAA Record**: Maps a domain to an IPv6 address.
- **CNAME Record**: Points one domain to another domain (alias).
- **MX Record**: Specifies the mail servers for a domain.
- **TXT Record**: Holds arbitrary text for domain verification, security, etc.
- **PTR Record**: Performs reverse DNS lookups (IP to domain).

SOME TOP LEVEL DOMAINS

Generic Top-Level Domains

- **.com** = Commercial
- **.org** = Organizations
- **.net** = Network-related Entities
- **.info** = Information Websites
- **.biz** = Businesses
- **.name** = Personal Websites
- **.pro** = Professional (e.g., doctors, lawyers)
- **.edu** = Educational Institutions
- **.gov** = Government Entities
- **.mil** = Military Organizations

Sponsored Top-Level Domains

- **.aero** = Aviation Industry
- **.asia** = Asia-Pacific Region
- **.cat** = Catalan language and Culture
- **.coop** = Cooperatives
- **.int** = International Organizations
- **.jobs** = Employment-related Sites
- **.mobi** = Mobile-Compatible Websites
- **.post** = Postal Websites
- **.travel** = Travel and Tourism Industry

Country Code Top-Level Domains

- **.us** = United States
- **.uk** = United Kingdom
- **.ca** = Canada
- **.de** = Germany
- **.jp** = Japan
- **.in** = India
- **.au** = Australia
- **.fr** = France
- **.cn** = China
- **.br** = Brazil

Newer Generic Top-Level Domains

- **.app** = Applications and Software
- **.blog** = Blogs and Personal Websites
- **.shop** = E-Commerce and Online Stores
- **.tech** = Technology-related Sites
- **.online** = General use for online Websites
- **.site** = General use of Websites
- **.life** = Lifestyle-focused Content
- **.store** = Retail and E-Commerce

SECURITY RISKS AND MISCONFIGURATION IN DNS



Security Risks and Misconfiguration in DNS

01 **Unsecured Zone Transfers:** Allows attackers to retrieve the entire DNS database.

02 **Misconfigured Records:** Exposes internal domains, IPs, or sensitive information.

03 **DNS Spoofing/Poisoning:** Manipulates DNS records to redirect traffic to malicious servers.

Preventing DNS Abuse

01 **Secure Zone Transfers:** Restrict transfers to trusted IPs only.

02 **Harden DNS Servers and Regular Monitoring:** Use secure protocols (e.g., DNSSEC) to validate DNS responses and continuously check for misconfigured records or anomalies in DNS traffic.

03 **Minimize Exposure:** Avoid unnecessary public DNS records and use internal DNS for sensitive resources.

LEGAL AND ETHICAL ASPECTS OF FOOTPRINTING



Ethical hacking involves obtaining permission from the target organization to test and evaluate their systems for vulnerabilities.

It is done with the aim of Securing the systems without causing harm and to comply with laws and maintain professional integrity.

Importance of Ethics in Reconnaissance

01 **Permission is Key:** Conducting reconnaissance without explicit authorization can be considered illegal.

02 **Avoiding Malicious Intent:** Information gathering must be used to strengthen security, not exploit vulnerabilities.

03 **Compliance with Regulations:** Activities must align with data protection and privacy laws (e.g., GDPR, HIPAA).

LEGAL AND ETHICAL ASPECTS OF FOOTPRINTING



Legal Frameworks Governing Reconnaissance

01 **Cybercrime Laws:** Unauthorized footprinting or reconnaissance can violate laws such as Computer Fraud and Abuse Act (CFAA) in the U.S., Information Technology Act (2000) in India and General Data Protection Regulation (GDPR) in the EU.

02 **Privacy Laws:** Collecting personal data during reconnaissance might breach privacy regulations, especially if done without consent and information is shared or misused.

03 **Contractual Obligations:** Organizations often formalize ethical hacking activities through NDA (Non-Disclosure Agreement) and Penetration Testing Agreement.

Ethical Practices in Reconnaissance obtain explicit permission, also define the scope clearly and document findings transparently with respecting privacy.

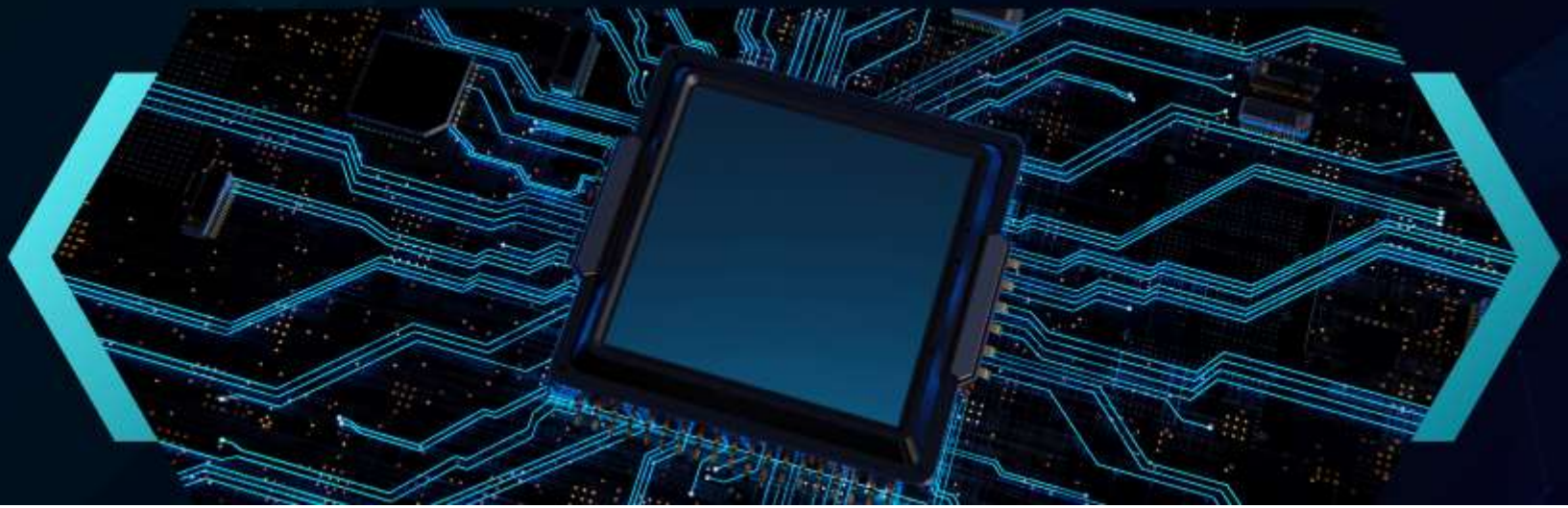
Unethical Practices in Reconnaissance includes Unauthorized access, Social Engineering for Malicious Intent and Exploiting Exposed Data.

PRACTICAL EXERCISE 1

Game type practical

Students has to perform Footprinting for Social Media Cracking and mobile password cracking with the help of some mentioned tools:

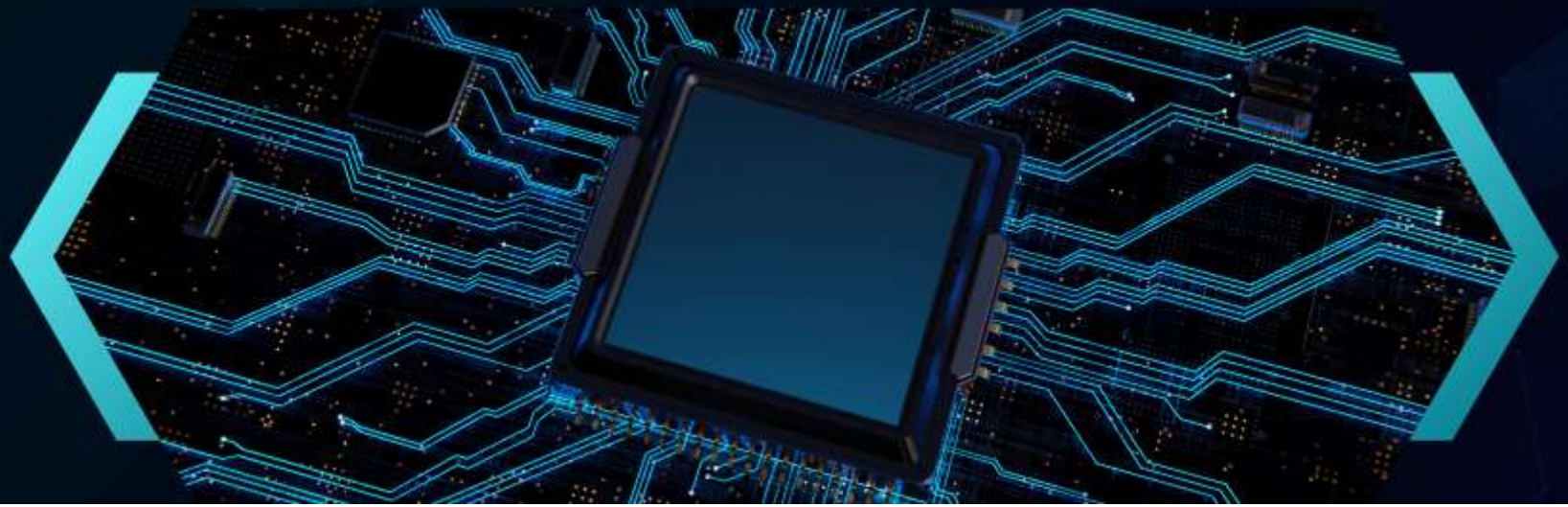
1. **Footprinting Tools**: Whois Lookup, Iplogger, GrabifyIplogger, Shodan, FOCA, WayBack Machine.
2. **Phishing tools**: Zphisher tool, Evilginx2, SEToolkit, HiddenEye, Gophish, BlackEye.
3. **Network Footprinting Tools**: Nmap, Wireshark, Maltego, Recon-ng.



PRACTICAL EXERCISE 2

DNS Enumeration Tools

1. **Sublist3r**
2. **SubFinder**
3. **DNSrecon,**
4. **DNSenum**
5. **DNSlookup**
6. **Dig**
7. **Nmap**





CONTACT US

+91 7992281130

www.suviksan.in

learning@suviksan.com

Unit No:1006,Tower-A,ATS Bouquet,Sector-132,Noida(U.P.), INDIA-201305

THANK YOU

HTTPS://SUVIKSAN.IN